CYBERSECURITY

120 Multiple-Choice Questions

A structured question bank covering core cybersecurity domains — from beginner fundamentals to advanced concepts.

DOMAINS COVERED

- Footprinting & OSINT
- Enumeration
- Cryptography
- Network Security
- Web & API Security
- Penetration Testing
- Linux & Endpoint Security
- Cloud Security
- SOC & Incident Response
- Malware Analysis
- Wireless Security
- GRC & Identity Security
- Secure Development & Containers

Format: 4 options per question • Beginner, Intermediate and Advanced levels • Answer key at the end

Suitable for self-assessment, classroom quizzes, interview preparation, and cybersecurity training. Questions are intended for authorized, defensive learning.

Footprinting & OSINT

Q1. Which DNS record maps a domain name to an IPv4 address? **[Beginner]**

A. AAAA
B. A
C. MX
D. PTR

Q2. What is the primary purpose of WHOIS lookups? **[Beginner]**

A. Crack passwords
B. Identify domain registration details
C. Scan open ports
D. Decrypt TLS traffic

Q3. Which tool is commonly used to query DNS records? **[Beginner]**

A. dig
B. John the Ripper
C. Aircrack-ng
D. Volatility

Q4. What does the robots.txt file commonly communicate? **[Beginner]**

A. Firewall rules
B. Search-engine crawling preferences
C. User passwords
D. TLS cipher suites

Q5. Which search operator can restrict results to a specific website? **[Intermediate]**

A. cache:
B. site:
C. link:
D. intitleonly:

Q6. What is passive reconnaissance? **[Intermediate]**

A. Sending exploit payloads
B. Gathering information without directly interacting with target systems
C. Brute-forcing SSH
D. Changing DNS records

Q7. Which record is used to identify mail servers for a domain? **[Intermediate]**

A. MX
B. TXT
C. NS
D. SOA

Q8. What is certificate transparency primarily useful for during domain reconnaissance? **[Advanced]**

A. Recovering private keys
B. Discovering publicly logged TLS certificates and related hostnames
C. Bypassing MFA
D. Testing SQL injection

Q9. What is a key limitation of using Shodan data for an assessment? **[Advanced]**

A. It only indexes private IPs
B. Results may be stale and do not prove current exploitability
C. It cannot identify services
D. It requires source code

Enumeration

Q10. Which protocol commonly uses TCP port 22? **[Beginner]**

A. FTP

B. SSH
C. DNS
D. SMTP

Q11. Which command-line tool can list SMB shares on an authorized network? **[Beginner]**

A. smbclient
B. tcpdump
C. traceroute
D. openssl

Q12. What does an open TCP port generally indicate? **[Beginner]**

A. A service is accepting connections
B. The host is powered off
C. The port is encrypted
D. The service is vulnerable

Q13. Which Nmap option performs service/version detection? **[Intermediate]**

A. -O
B. -sV
C. -sn
D. -Pn

Q14. What is the purpose of SNMP enumeration? **[Intermediate]**

A. Discover management data and device information
B. Decode passwords in TLS
C. Test browser storage
D. Enumerate Git commits

Q15. Which LDAP attribute commonly contains a user's login name? **[Intermediate]**

A. uid
B. jpegPhoto
C. userCertificate
D. createTimestamp

Q16. What does a DNS zone transfer attempt retrieve? **[Intermediate]**

A. A copy of DNS zone data
B. TLS session keys
C. Firewall logs
D. Wi-Fi handshakes

Q17. Why should an assessor enumerate both TCP and UDP services where in scope? **[Advanced]**

A. All services use TCP
B. Some services are exposed over UDP and would otherwise be missed
C. UDP is always encrypted
D. UDP scans reveal source code

Q18. What does an Nmap 'filtered' port state usually mean? **[Advanced]**

A. A response confirms the port is open
B. A filtering device prevents the probe from determining the state
C. The port is definitely closed
D. The service is vulnerable

Cryptography

Q19. Which cryptographic property ensures data has not been altered? **[Beginner]**

A. Confidentiality
B. Integrity
C. Availability
D. Non-repudiation

Q20. Which is a symmetric encryption algorithm? **[Beginner]**

A. AES
B. RSA
C. ECC
D. Diffie-Hellman

Q21. What is a cryptographic hash designed to produce? **[Beginner]**

A. A fixed-length digest
B. A reversible ciphertext
C. A private key
D. A network route

Q22. Why should passwords generally be stored using a salted password-hashing scheme? **[Intermediate]**

A. To make them reversible
B. To slow offline guessing and prevent identical passwords having identical hashes
C. To avoid authentication
D. To compress the database

Q23. Which algorithm is commonly used for authenticated encryption? **[Intermediate]**

A. AES-GCM
B. MD5
C. Base64
D. ROT13

Q24. What does a digital signature primarily provide? **[Intermediate]**

A. Confidentiality only
B. Authenticity, integrity, and support for non-repudiation
C. Data compression
D. Availability

Q25. What is the purpose of a key-exchange protocol such as Diffie-Hellman? **[Intermediate]**

A. Agree on shared secret material over an insecure channel
B. Hash a file
C. Store passwords
D. Sign a certificate

Q26. Why is nonce reuse dangerous with AES-GCM? **[Advanced]**

A. It weakens DNS
B. It can expose plaintext relationships and undermine authentication security
C. It increases key length
D. It disables hashing

Q27. What is forward secrecy in TLS? **[Advanced]**

A. Old sessions remain protected if the server's long-term private key is later compromised
B. Certificates never expire
C. All traffic is public
D. Passwords are never transmitted

Network Security

Q28. Which OSI layer is responsible for routing between networks? **[Beginner]**

A. Physical
B. Data Link
C. Network
D. Presentation

Q29. What is the default port for HTTPS? **[Beginner]**

A. 21
B. 25
C. 80

D. 443

Q30. What does a firewall primarily do? **[Beginner]**

A. Filter network traffic according to rules
B. Replace endpoint antivirus
C. Encrypt every file
D. Manage source code

Q31. What is the purpose of a VLAN? **[Intermediate]**

A. Segment a Layer 2 network logically
B. Encrypt DNS responses
C. Replace routing
D. Store certificates

Q32. Which protocol securely replaces Telnet for remote command-line access? **[Intermediate]**

A. FTP
B. SSH
C. TFTP
D. HTTP

Q33. What is ARP spoofing? **[Intermediate]**

A. Forging ARP messages to associate an attacker's MAC address with another IP
B. Forging TLS certificates
C. Guessing DNS names
D. Flooding SMTP

Q34. What is the main purpose of a VPN? **[Intermediate]**

A. Create an encrypted tunnel across an untrusted network
B. Increase CPU speed
C. Remove endpoint logs
D. Disable authentication

Q35. Which control helps mitigate IP spoofing at a network edge? **[Advanced]**

A. Ingress/egress filtering
B. Open relay
C. Anonymous FTP
D. Disabling logs

Q36. What does mutual TLS add beyond typical server-authenticated TLS? **[Advanced]**

A. Client certificate authentication as well
B. No encryption
C. Password storage
D. DNSSEC validation

Web & API Security

Q37. What does XSS allow an attacker to do in a victim's browser? **[Beginner]**

A. Execute attacker-controlled script in a trusted site context
B. Physically access the server
C. Decrypt the disk
D. Change BGP routes

Q38. What is SQL injection? **[Beginner]**

A. Injecting untrusted input into database queries as executable SQL
B. Encrypting SQL backups
C. Scanning a database port
D. Compressing tables

Q39. Which HTTP method is generally intended to retrieve a resource? **[Beginner]**

A. GET

B. DELETE
C. PATCH
D. CONNECT

Q40. Which is the strongest general defense against SQL injection? **[Intermediate]**

A. Parameterized queries
B. Hiding error messages only
C. Client-side validation only
D. Changing the database port

Q41. What does CSRF exploit? **[Intermediate]**

A. A browser's authenticated session to perform an unwanted action
B. Weak Wi-Fi encryption
C. Unpatched firmware only
D. DNS cache poisoning

Q42. What is an IDOR/BOLA vulnerability? **[Intermediate]**

A. Missing object-level authorization checks
B. Incorrect TLS version
C. Weak password hashing
D. Excessive logging

Q43. Which cookie attribute helps prevent JavaScript from reading a session cookie? **[Intermediate]**

A. HttpOnly
B. Domain
C. Path
D. Max-Age

Q44. What is a common risk of permissive CORS configuration using wildcard origins with credentials? **[Advanced]**

A. Cross-origin exposure of sensitive responses
B. Stronger encryption
C. Automatic rate limiting
D. Database normalization

Q45. What does mass assignment in an API commonly involve? **[Advanced]**

A. Binding user-controlled fields to sensitive model properties without adequate allowlisting
B. Sending too many packets
C. Hashing all API responses
D. Using a reverse proxy

Penetration Testing

Q46. What is the first essential step before a penetration test? **[Beginner]**

A. Obtain authorization and define scope
B. Exploit the target
C. Delete logs
D. Publish findings

Q47. What is the purpose of a rules-of-engagement document? **[Beginner]**

A. Define permitted activities, limits, contacts, and timing
B. List employee passwords
C. Guarantee no findings
D. Replace the final report

Q48. What does a vulnerability assessment primarily identify? **[Beginner]**

A. Potential weaknesses, often without proving exploitation
B. Only successful data theft
C. Employee performance
D. Software licensing

Q49. In a typical penetration test, what follows reconnaissance and scanning? **[Intermediate]**

A. Enumeration and vulnerability analysis
B. Public disclosure immediately
C. Billing
D. Data destruction

Q50. What is the purpose of a proof of concept (PoC)? **[Intermediate]**

A. Demonstrate that a vulnerability is real with controlled evidence
B. Replace authorization
C. Guarantee remediation
D. Hide the issue

Q51. What should a tester do if testing unexpectedly impacts production availability? **[Intermediate]**

A. Stop or pause testing and follow the agreed escalation process
B. Continue at higher intensity
C. Delete monitoring alerts
D. Expand scope

Q52. Which item is most useful in a finding's evidence section? **[Intermediate]**

A. Reproducible steps and sanitized request/response evidence
B. Unsupported speculation
C. Personal opinions only
D. Unrelated screenshots

Q53. What is the main difference between black-box and white-box testing? **[Advanced]**

A. Amount of internal knowledge provided to the tester
B. Whether the target uses Linux
C. Whether tools are automated
D. Whether reports are required

Q54. Why should post-exploitation actions be tightly controlled? **[Advanced]**

A. They can expose data, alter systems, or disrupt operations
B. They always improve security
C. They are legally required in every test
D. They remove the need for evidence

Linux & Endpoint Security

Q55. Which Linux command displays the current user? **[Beginner]**

A. whoami
B. chmod
C. grep
D. mount

Q56. What does chmod 600 file typically mean? **[Beginner]**

A. Owner can read/write; group and others have no permissions
B. Everyone can read/write
C. Owner can execute only
D. File is deleted

Q57. Which file commonly stores local user account information on Linux? **[Beginner]**

A. /etc/passwd
B. /etc/hosts.allow
C. /var/log/dmesg
D. /boot/grub

Q58. What is the principle of least privilege? **[Intermediate]**

A. Give users/processes only permissions needed for their tasks
B. Give all users root
C. Disable all accounts

D. Share credentials

Q59. Which command is commonly used to inspect listening sockets on modern Linux? **[Intermediate]**

A. ss -lntup
B. pwd -P
C. touch -a
D. uname -r

Q60. What is a systemd service unit used for? **[Intermediate]**

A. Define and manage a system service
B. Encrypt a partition automatically
C. Compile a kernel module
D. Resolve DNS only

Q61. Which Windows feature can isolate suspicious files and processes for analysis? **[Intermediate]**

A. Windows Sandbox
B. Disk Cleanup
C. Sticky Keys
D. Paint

Q62. What is the security benefit of Linux capabilities? **[Advanced]**

A. Grant specific privileged operations without giving full root privileges
B. Disable all kernel checks
C. Replace file permissions entirely
D. Encrypt user home directories

Q63. What does Secure Boot aim to protect? **[Advanced]**

A. Integrity of the boot chain by verifying trusted boot components
B. Browser cookies
C. Wi-Fi passwords
D. Database backups

Cloud Security

Q64. What is the shared responsibility model? **[Beginner]**

A. Cloud provider and customer have different security responsibilities
B. Provider is responsible for everything
C. Customer is responsible for physical data centers
D. Security is optional

Q65. What does IAM primarily control? **[Beginner]**

A. Identity and access permissions
B. CPU temperature
C. DNS caching
D. Image compression

Q66. Why should cloud storage buckets avoid public access by default? **[Beginner]**

A. To prevent unintended exposure of stored data
B. To improve download speed
C. To enable anonymous administration
D. To disable encryption

Q67. What is the purpose of AWS CloudTrail? **[Intermediate]**

A. Record account/API activity for auditing
B. Scan container images only
C. Replace IAM
D. Manage DNS zones

Q68. Which AWS service detects suspicious activity using threat intelligence and behavioral analysis? **[Intermediate]**

A. GuardDuty

B. CloudFormation
C. S3 Transfer Acceleration
D. Route 53

Q69. What is a security group in AWS? **[Intermediate]**

A. Stateful virtual firewall for supported resources
B. Physical security team
C. Object storage bucket
D. Billing report

Q70. What is the main benefit of using short-lived cloud credentials? **[Intermediate]**

A. Reduce exposure window if credentials are compromised
B. Remove need for authorization
C. Make keys public
D. Disable audit trails

Q71. What is the risk of an overly permissive cloud IAM policy? **[Advanced]**

A. Excessive privileges can enable data access or resource control
B. It prevents API calls
C. It encrypts all data
D. It blocks logging

Q72. What is workload identity federation commonly used for? **[Advanced]**

A. Let external workloads obtain scoped cloud credentials without long-lived static keys
B. Share root passwords
C. Disable MFA
D. Store access keys in source code

SOC & Incident Response

Q73. What does SIEM stand for? **[Beginner]**

A. Security Information and Event Management
B. Secure Internet Email Method
C. System Identity Encryption Module
D. Security Inspection Endpoint Monitor

Q74. What is a security alert? **[Beginner]**

A. A notification that a rule or analytic detected potentially suspicious activity
B. Proof of a confirmed breach
C. A software update
D. A backup file

Q75. What is phishing? **[Beginner]**

A. Deceptive communication intended to trick users into actions or disclosure
B. A network routing protocol
C. Disk encryption
D. A patching method

Q76. What is the first priority when responding to an active incident? **[Intermediate]**

A. Follow the response plan, assess safety/business impact, and contain appropriately
B. Wipe every affected system immediately
C. Post details publicly
D. Delete evidence

Q77. What is a false positive in security monitoring? **[Intermediate]**

A. Benign activity incorrectly flagged as malicious
B. Malicious activity missed by detection
C. A confirmed compromise
D. A failed backup

Q78. What is the purpose of a playbook in a SOC? **[Intermediate]**

A. Provide repeatable investigation and response steps
B. Store encryption keys
C. Replace incident ownership
D. Disable alerts

Q79. Which data source is especially useful for investigating a suspicious process launch? **[Intermediate]**

A. Endpoint process and command-line telemetry
B. Marketing analytics
C. Printer toner level
D. Website theme

Q80. What is the purpose of preserving chain of custody? **[Advanced]**

A. Document evidence handling to support integrity and admissibility
B. Improve network speed
C. Encrypt all email
D. Rotate user passwords

Q81. What does mean time to detect (MTTD) measure? **[Advanced]**

A. Average time taken to identify an incident
B. Time to patch a server
C. Time to restore a backup only
D. Time to onboard a user

Malware Analysis

Q82. What is ransomware? **[Beginner]**

A. Malware that encrypts or blocks access to data and demands payment
B. A secure backup format
C. A firewall rule
D. A password manager

Q83. What is a hash commonly used for in malware analysis? **[Beginner]**

A. Identify and compare files
B. Execute code safely
C. Decrypt all malware
D. Block every network port

Q84. What is a sandbox in malware analysis? **[Beginner]**

A. An isolated environment for observing suspicious files
B. A production domain controller
C. A public file share
D. A password vault

Q85. What is static malware analysis? **[Intermediate]**

A. Examining a sample without executing it
B. Running it on a live corporate network
C. Deleting its strings
D. Blocking its IP address

Q86. What can strings extraction reveal? **[Intermediate]**

A. Embedded text such as URLs, commands, and suspicious messages
B. The complete source code in every case
C. The attacker's identity with certainty
D. All runtime behavior

Q87. What is a persistence mechanism? **[Intermediate]**

A. A technique malware uses to survive reboot or user logoff
B. A one-time network packet
C. A hash algorithm

D. A backup checksum

Q88. What is dynamic analysis? **[Intermediate]**

A. Observing a sample while it executes in a controlled environment
B. Reading only its filename
C. Checking a website's CSS
D. Calculating file size only

Q89. Why is an isolated, instrumented lab important for dynamic analysis? **[Advanced]**

A. It limits unintended spread while capturing behavior
B. It guarantees malware cannot detect the lab
C. It makes samples harmless
D. It removes the need for snapshots

Q90. What does process injection generally allow malware to do? **[Advanced]**

A. Execute code within another process's address space
B. Change a domain's MX record
C. Encrypt a backup tape only
D. Reset a router

Wireless Security

Q91. Which Wi-Fi security standard is generally stronger than WPA2 when properly configured? **[Beginner]**

A. WEP
B. WPA3
C. Open authentication
D. WPA

Q92. What does an SSID identify? **[Beginner]**

A. A wireless network name
B. A router's private key
C. An IP subnet mask
D. A TLS certificate

Q93. What is the risk of using an open public Wi-Fi network? **[Beginner]**

A. Traffic may be exposed to local attackers, especially without end-to-end encryption
B. It always installs malware
C. It disables HTTPS
D. It guarantees identity theft

Q94. What is a rogue access point? **[Intermediate]**

A. An unauthorized wireless access point connected to or impersonating a network
B. A patched router
C. A DNS server
D. A network printer

Q95. What is the purpose of 802.1X in enterprise Wi-Fi? **[Intermediate]**

A. Port-based network access control and authentication
B. Wireless encryption key recovery
C. DNS resolution
D. Packet compression

Q96. What is an evil twin attack? **[Intermediate]**

A. A fake access point impersonating a legitimate Wi-Fi network
B. A duplicate hard drive
C. A forged email signature
D. A Bluetooth pairing update

Q97. Which practice improves enterprise wireless security? **[Intermediate]**

A. Use WPA2/WPA3-Enterprise with strong authentication and certificate validation

B. Share one password publicly
C. Disable encryption
D. Use WEP

Q98. Why is certificate validation important in EAP-TLS/PEAP deployments? **[Advanced]**

A. It helps prevent clients from trusting a malicious authentication server
B. It increases radio range
C. It hides the SSID
D. It replaces access control

Q99. What is the main security benefit of Protected Management Frames (802.11w)? **[Advanced]**

A. Protect certain management frames against spoofing and forgery
B. Encrypt all application data
C. Prevent every deauthentication attack in every configuration
D. Replace WPA3

Q100. What is a key risk of Wi-Fi Protected Setup (WPS) PIN mode on poorly secured devices? **[Advanced]**

A. It may enable practical PIN-guessing attacks
B. It disables DHCP
C. It exposes TLS private keys
D. It prevents firmware updates

GRC & Identity Security

Q101. What does MFA require? **[Beginner]**

A. Two or more distinct authentication factors
B. Two passwords of the same type
C. A username only
D. A security question only

Q102. What is the CIA triad? **[Beginner]**

A. Confidentiality, Integrity, Availability
B. Control, Inspection, Authorization
C. Cybersecurity, Intelligence, Audit
D. Confidentiality, Identification, Authentication

Q103. What is a vulnerability? **[Beginner]**

A. A weakness that could be exploited
B. A confirmed attack in every case
C. A security policy
D. A backup schedule

Q104. What is risk commonly assessed as a combination of? **[Intermediate]**

A. Likelihood and impact
B. CPU and RAM
C. Cost and color
D. Username and password

Q105. What is the purpose of an access review? **[Intermediate]**

A. Confirm users retain only appropriate access
B. Increase all user privileges
C. Delete audit records
D. Disable SSO

Q106. What does SSO provide? **[Intermediate]**

A. One authentication event to access multiple trusted applications
B. One password shared by all employees
C. Anonymous access
D. Automatic encryption of databases

Q107. Which framework provides a widely used cybersecurity risk management structure? **[Intermediate]**

A. NIST Cybersecurity Framework
B. JPEG
C. SMTP
D. HTML5

Q108. What is the purpose of a threat model? **[Advanced]**

A. Identify assets, trust boundaries, threats, and mitigations
B. Guarantee that no attack is possible
C. Replace penetration testing
D. Measure employee satisfaction

Q109. What is the principle of separation of duties? **[Advanced]**

A. Split sensitive tasks among multiple people or roles to reduce abuse and error
B. Give one person all privileges
C. Remove approval workflows
D. Share administrator accounts

Q110. What is a compensating control? **[Advanced]**

A. An alternative safeguard used when a preferred control is infeasible
B. A control that increases risk
C. A control that is never documented
D. A replacement for risk assessment

Secure Development & Containers

Q111. What is the purpose of code review? **[Beginner]**

A. Find defects and security issues before code is merged or released
B. Increase binary size
C. Replace testing entirely
D. Hide vulnerabilities

Q112. What is a software dependency? **[Beginner]**

A. An external library or component used by an application
B. A firewall rule
C. A user account
D. A network cable

Q113. Where should application secrets generally not be stored? **[Beginner]**

A. In source code repositories
B. In a managed secret store
C. In an approved vault
D. In a protected runtime secret mechanism

Q114. What is software composition analysis (SCA) used for? **[Intermediate]**

A. Identify third-party components and known vulnerabilities/licenses
B. Encrypt source code
C. Monitor employee attendance
D. Replace authentication

Q115. What is the purpose of input validation on the server side? **[Intermediate]**

A. Enforce expected formats and constraints on untrusted data
B. Trust all browser checks
C. Disable output encoding
D. Make SQL queries dynamic

Q116. What is a container image? **[Intermediate]**

A. A packaged filesystem and metadata used to create containers
B. A virtual machine hypervisor
C. A network firewall

D. A TLS certificate

Q117. Why should containers run as non-root where possible? **[Intermediate]**

A. Reduce impact if the application is compromised
B. Increase image size
C. Disable namespaces
D. Make secrets public

Q118. What is the purpose of an SBOM? **[Advanced]**

A. Inventory software components and dependencies in a product
B. Store user passwords
C. Scan wireless channels
D. Replace source control

Q119. What does a read-only container filesystem help reduce? **[Advanced]**

A. Unauthorized or unexpected modification of the container filesystem
B. TLS handshake time
C. DNS record count
D. CPU instruction set

Q120. What is a secure CI/CD pipeline practice? **[Advanced]**

A. Protect pipeline credentials, restrict permissions, and verify build artifacts
B. Give every workflow administrator access
C. Print secrets in logs
D. Skip dependency checks

ANSWER KEY

Correct options for all 120 questions

1. B	2. B
3. A	4. B
5. B	6. B
7. A	8. B
9. B	10. B
11. A	12. A
13. B	14. A
15. A	16. A
17. B	18. B
19. B	20. A
21. A	22. B
23. A	24. B
25. A	26. B
27. A	28. C
29. D	30. A
31. A	32. B
33. A	34. A
35. A	36. A
37. A	38. A
39. A	40. A
41. A	42. A
43. A	44. A
45. A	46. A
47. A	48. A
49. A	50. A
51. A	52. A
53. A	54. A
55. A	56. A
57. A	58. A

59. A	60. A
61. A	62. A
63. A	64. A
65. A	66. A
67. A	68. A
69. A	70. A
71. A	72. A
73. A	74. A
75. A	76. A
77. A	78. A
79. A	80. A
81. A	82. A
83. A	84. A
85. A	86. A
87. A	88. A
89. A	90. A
91. B	92. A
93. A	94. A
95. A	96. A
97. A	98. A
99. A	100. A
101. A	102. A
103. A	104. A
105. A	106. A
107. A	108. A
109. A	110. A
111. A	112. A
113. A	114. A
115. A	116. A
117. A	118. A
119. A	120. A

Note: These questions are designed for learning and assessment. In real-world security testing, always obtain explicit authorization and follow the agreed scope and rules of engagement.